지속적인 OS 보안사항 적용을 위한 시스템 요구사항

항목	내용
목적	E3 전 장치에 최신 OS·보안 패치를 지속 적용하고 SBOM을 제출하는 시스템의 최소 요구사항 정의
상태	초안
작성일	2026-10-19
작성자	김명환

1. 요약

- 대상: 당사가 제공하는 E3-... 계열 제품 전체. 현재 4종(DP, RDP, HDLC, GW), 수십 대
- 현황: OS 전부 지원 종료(EOL), 배포 수동(tar 복사, 이미지 교체)
- 요구: KT가 SBOM 제출 요구 → "생산 시점 펌웨어 기준"에서 "지속 보안 패치 + SBOM"으로 정책 변경
- 방안
- 전 장치를 Debian 13 계열 OS로 전환
- 외부망 스테이징 서버에서 Debian 저장소를 미러링·서명·보안 검사 후, 검사 완료된 서버(저장소) 단위로 폐쇄망 배포 서버에 반입
- 서버 측은 Debian 표준 미러링·저장소 도구를 설정만으로 사용, 일상 갱신은 무인 수행
- 장치는 표준 apt로 업그레이드. 서버가 업그레이드 신호 전송 → 장치가 로컬에서 apt 실행
- 제품 설치 구성(이미지)마다 SBOM 자동 생성
- 현장 장치는 microSD를 새 이미지로 1회 교체, 이후 원격 패치

2. 배경

2.1 E3 시스템과 대상 장치

E3(N-ELITE 계열): KT 국사 전원·설비 감시 시스템. 현장 장치와 상위 관제(Host)로 구성. 당사 제품은 E3-... 계열(E3-DP, E3-RDP, E3-HDLC, E3-GW)이며 아래 4종이 현재 대상.

제품	역할(확인 범위)	보드	현재 OS
E3-DP	현장 데이터 처리. 장비 값 수집, 경보 판정, 제어, Host 연동. 데몬 약 13개가 공유메모리로 협업	NanoPi NEO (Allwinner H3, armhf 32bit, RAM 512MB)	Ubuntu 16.04.2, 커널 3.4
E3-RDP (RPMS)	DP 계열 현장 장치	NanoPi (H3)	Ubuntu 16.04.2
E3-HDLC	현장 장치. 소스 미확정	NanoPi (H3)	Ubuntu 16.04.6
E3-GW	Modbus TCP 게이트웨이. DP 사설망(192.168.123.0/24) 뒤에 위치	Raspberry Pi (armv7 커널)	Raspbian 8, 커널 4.4

- 부팅: microSD
- NanoPi 3종: 동일 H3 armhf → OS 기반 공유

2.2 현재 문제

문제	내용
OS 지원 종료	Ubuntu 16.04, Raspbian 8. SBOM 점검에서 지적
수동 배포	장치에서 소스 컴파일 후 /opt/*/bin tar 복사. 이미지는 장치당 약 8GB .img 기록
버전 관리	소스는 날짜별 tar 사본. 변경 이력은 history.txt 수기
SBOM	제품별 4종(컴포넌트 441~593개) 제출 완료. 갱신·재제출 체계 없음

2.3 정책 변화

구분	기존	변경
기조	생산 시점 펌웨어 기준	SBOM 적용 + 지속 보안 업그레이드
배포	이미지 교체, tar 수동	apt 패키지
OS	EOL	Debian 안정판 (Debian 13 Trixie)

2.4 KT SBOM 제출 요건 (KT 가이드 요약)

항목	요건
제출 단위	납품 자재(제품) 단위
제출 시점	장비 평가, 계약, 계약서 정기 일정, 취약점 조치 이행(신규 취약점 확인 포함)
처리	KT 정보보안실 취약점 점검 → 결과 전달 → 취약점 있으면 조치 후 재제출
형식	CycloneDX 1.4/1.5 또는 SPDX 2.2/2.3, JSON
필수 항목	문서 정보, 루트 컴포넌트(납품 제품), 컴포넌트별 type·name·version·purl(pkg:)·license, 직접·전이 의존성. 누락 시 재제출
생성 방식	소스 또는 이미지에서 추출. 바이너리 추출은 부적합. 빌드·패키지 설치 완료 상태에서 생성 권장
제출 전 점검	파일 1KB 이상 / 최상위 컴포넌트가 납품 제품과 동일 / 전 컴포넌트 purl 존재 / 의존성 포함 / 포맷 검증
파일명	(계약번호/장비평가게시번호)자재코드_SW자재명

3. 범위

3.1 포함

- 신규 OS(Debian 계열) 적용, 장치 전환
- 외부망 스테이징 서버(미러링·서명·보안 검사), 폐쇄망 Debian 배포 서버, 반입
- 앱 deb 패키지화
- 업그레이드 신호와 장치 측 실행 구성요소
- SBOM 생성, 취약점 대조

3.2 제외

항목	사유
실행 프로그램(앱) 보안 (내부 UDP 프로토콜 암호화·인증, 앱 로그·계정 처리 등)	별도 검토
앱 기능 변경, Host 시스템(업그레이드 신호 송신 포함), 하드웨어 변경	목적 외
업그레이드 자동 모드(장치의 서버 자동 접속)	후속 단계
취약점 영향 판단 문서(VEX), 장치별 설치 목록 조회, 선별 미러링	필요 시 추가
운영 절차(유지보수 창, 순차 적용, 이전 카드 보관 기간, 계측 공백 측정)	별도 정의

4. 제약 및 전제

ID	내용
C-01	운영 환경은 KT 시스템 망(폐쇄망). 외부 인터넷 불가
C-02	폐쇄망 배포 서버는 외부에서 보안 검사를 마친 서버(저장소) 단위로만 갱신. 폐쇄망 안에서 외부 패치를 직접 수령하지 않음. 반입 매체·경로는 KT 반입 절차 준수
C-03	장치 OS 패치는 표준 Debian apt 방식
C-04	소스 비공개. 공개·외부 서비스 호스팅 금지, 조직이 관리하는 환경에서만 보관·빌드
C-05	하드웨어(NanoPi, Raspberry Pi) 변경 없음
C-06	NanoPi 계열: armhf 32bit, RAM 512MB
C-07	현행 앱 전제: /opt/e3dp/bin 경로, scheck 기동, 공유메모리 구조
C-08	장치 수 수십 대
C-09	배포 서버는 KT 시스템 망 안에 설치. 장치 → 서버 HTTP/HTTPS 통신 허용
C-10	GW 보드는 armv7 이상으로 Debian 13 armhf 지원 모델. 적용 전 모델 확인

5. 기능 요구사항

5.1 OS·이미지

ID	요구
F-01	지원 중인 Debian 계열 안정판 사용. NanoPi 3종은 Debian 13 armhf, GW는 Raspberry Pi OS Lite(Debian 13 기반, 32bit)
F-02	신규 OS에서 기존 앱 기능(수집·판정·경보·제어·Host 연동) 동일 동작
F-03	제조사 전용 라이브러리(libfahw) 의존 제거 (wan_led, 검수 도구)
F-04	설치 이미지: 보드 계열별(NanoPi, Raspberry Pi). 배포 스냅샷에서 빌드. 앱·e3-updater·저장소 설정·서명 공개키 포함. 첫 부팅 시 루트 파티션 자동 확장

ID	요구
F-05	이미지에 공통 SSH 키·비밀번호를 넣지 않음

5.2 패키지

ID	요구
F-06	DP, RDP, GW 앱은 소스 빌드 deb, HDLC는 현행 바이너리 재패키징 deb. 버전은 소스 VERSION 파일 기준으로 부여하고 기존 버전 코드와 매핑(예: V030319 → 3.3.19)
F-07	장치는 배포 서버 저장소만 참조. 외부 미러 주소 제거
F-08	한 서버에서 E3-... 계열 여러 제품·보드 관리. 신규 제품 추가는 설정 추가로 가능
F-09	GW용 저장소(Raspberry Pi OS가 참조하는 저장소 전부)를 Debian 저장소와 함께 미러
F-10	apt upgrade 시 장치별 설정·상태 파일(nelite.conf, nelite.db, alarm.db) 미덮어쓰기
F-11	업그레이드 시 앱 데몬 정지·공유메모리 정리·재기동 자동 수행
F-12	서버 측은 Debian 표준 미러링·저장소 도구(aptly)를 설정만으로 사용. 자체 개발 코드 없음

5.3 스테이징·반입

ID	요구
F-13	외부망 스테이징 서버가 Debian(GW용 포함) 저장소를 스케줄로 자동 미러링하고, 자체 deb를 반영하고, 취약점 DB를 갱신
F-14	반입 전 보안 검사: 업스트림 서명 검증, 패키지 해시 검증, 악성코드 검사, 취약점 대조(F-21). 결과를 기록하고 통과분만 반입
F-15	저장소는 자체 키로 서명. 서명은 스테이징 서버에서만 수행하고 폐쇄망 서버는 서명 키 미보유. 서명 키는 별도 보관·백업

5.4 스냅샷·반입본

ID	요구
F-16	날짜별 스냅샷 단위 배포. 같은 스냅샷은 같은 결과 보장
F-17	test는 외부 스테이징에서 시험 장치로 검증. 통과한 스냅샷만 prod로 확정해 반입. 현장 장치는 prod만 참조
F-18	반입 단위는 검사 완료된 서버 이미지 또는 저장소 볼륨. 폐쇄망 서버는 읽기 전용 서빙, 갱신은 반입본 교체. 이전 반입본·이전 버전 deb 보존, 되돌림 가능

5.5 SBOM·취약점

ID	요구
F-19	제품 설치 구성(이미지)마다 SBOM 자동 생성. CycloneDX 1.4/1.5 JSON. KT 필수 항목(§2.4)을 제출 전 자동 검증: 최상위 컴포넌트 일치, purl, 직접·전이 의존성, 파일 크기, 파일명
F-20	패키지 정보에 없는 구성요소(정적 링크 libPdu.a, KISA SHA-256 구현)를 수동 항목으로 SBOM에 포함
F-21	취약점 대조는 외부 스테이징 서버에서 최신 취약점 DB로 스케줄 수행. 결과를 반입본과 함께 제공
F-22	KT의 SBOM 제출·패치 요청 시 KT와 합의한 기간 내 SBOM 제출·패치 배포. 정기 적용 주기는 두지 않음

5.6 업그레이드 실행

ID	요구
F-23	서버 운영 도구가 업그레이드 신호 전송 → 장치가 로컬에서 표준 apt 실행(수동). 신호는 서명 또는 HMAC으로 인증하고 패키지명·주소를 싣지 않으며, 장치는 고정 저장소에서만 수령. 수신·실행은 앱 데몬과 분리된 공통 구성요소(가칭 e3-updater)가 담당하고 앱 코드는 수정하지 않음
F-24	업그레이드 후 기동 점검(데몬 생존, 통신)을 수행하고 결과(성공/실패, 설치 버전, 실행 커널 버전)를 서버에 보고. 이상 시 보고하며 복구는 수동
F-25	GW 신호는 DP의 e3-updater가 중계. GW의 apt 접속도 DP 경유

5.7 현장 전환

ID	요구
F-26	microSD를 새 이미지로 일괄 교체. 방문 교체는 장치당 1회, 이후 원격 패치
F-27	카드 교체 시 장치별 설정(nelite.conf: 장치 ID, 네트워크, Host 주소)을 새 카드로 이관하는 절차·도구 제공
F-28	nelite.db는 Host의 설정 재다운로드로 복원. alarm.db(경보 이력)는 이관하지 않음

6. 비기능 요구사항

ID	구분	요구
N-01	보안	스테이징 서버·배포 서버 접근과 서명 키 사용은 인가된 담당자로 제한
N-02	가용성	업그레이드 직후 smm이 정상 기동 중인 앱을 정체로 오판해 강제 재부팅하지 않을 것
N-03	자원	RAM 512MB, microSD 용량·쓰기 수명 범위 내 동작(apt 캐시·로그 보관 정책 포함)
N-04	추적성	장치 버전·스냅샷·SBOM 상호 추적

ID	구분	요구
N-05	운영	일상 갱신(미러링·서명·검사·SBOM 생성)은 스케줄로 무인 수행. 담당자는 검사 결과 확인, 반입 승인, 신호 전송, 결과 확인만 절차서대로 수행

7. 제품별 적용

영역	DP	RDP	HDLC	GW
신규 OS	Debian 13 armhf	Debian 13 armhf	Debian 13 armhf	Raspberry Pi OS Lite(Trixie)
앱 deb	소스 빌드	소스 빌드 (DP와 소스 차이 확인 후)	바이너리 재패키징 (소스 확정 전)	소스 빌드
저장소·SBOM·e3-updater	공통	공통	공통	공통 + GW용 저장소 미러
적용 순서	1차	2차	2차	마지막(OS 변경 폭 큼)

8. 구현 체크리스트

기능별로 중복을 제외해 정리. 항목 뒤 문장은 완료 조건, 괄호는 대응 요구 ID.

8.1 OS·이미지

- [ ] NanoPi 부팅: Debian 13 armhf 이미지가 NEO와 RDP·HDLC 보드에서 부팅 (F-01)
- [ ] GW 부팅: 보드 모델 확인 후 Raspberry Pi OS Lite(Trixie) 부팅 (F-01, C-10)
- [ ] 앱 동작: 전 데몬 기동, Host 연동·수집·판정·경보·제어가 기존 장치와 동일 (F-02)
- [ ] libfahw 제거: wan_led, 검수 도구가 신규 OS에서 동작 (F-03)
- [ ] 설치 이미지: 앱·e3-updater·저장소 설정·공개키 포함, 첫 부팅 시 파티션 자동 확장, 공통 SSH 키·비밀번호 없음 (F-04, F-05)

8.2 패키지

- [ ] deb 빌드: DP·RDP·GW 소스 빌드, HDLC 재패키징, 버전 규칙 적용 (F-06)
- [ ] 설정 보존: 설정·경보 이력 보유 장치에서 apt upgrade 전후 nelite.conf·nelite.db·alarm.db 해시 동일 (F-10)
- [ ] 데몬 재기동: 업그레이드 후 데몬 정상 기동, 공유메모리 정리 (F-11)
- [ ] 저장소 참조: 장치가 배포 서버 저장소만 참조, 외부 주소 접속 차단 (F-07)

8.3 스테이징 서버 (외부망)

- [ ] 자동 미러링: 스케줄 실행, Debian·GW용 저장소, 자체 deb 반영, 취약점 DB 갱신, 담당자 개입 없음 (F-13, N-05)
- [ ] 보안 검사: 서명·해시·악성코드·취약점 대조 수행, 결과 기록, 통과분만 반입 (F-14)
- [ ] 서명: 자체 키로 서명, 키 별도 보관·백업 (F-15)
- [ ] 시험: 시험 장치에서 test 스냅샷 업그레이드 검증 (F-17)

8.4 폐쇄망 배포 서버

- [ ] 설치 전제: KT 시스템 망 안에 설치, 장치 → 서버 HTTP/HTTPS 허용 (C-09)
- [ ] 구성: aptly 설정만 사용, 자체 코드 없음, 다제품·다보드 관리, 제품 추가는 설정 (F-08, F-09, F-12)
- [ ] 읽기 전용 서빙: 서명 키 없음, 서명이 변조된 저장소를 장치가 거부 (F-15, F-18)
- [ ] 갱신·되돌림: 반입본 교체로 갱신, 이전 반입본·이전 deb 보존 후 되돌림 수행 (F-18)
- [ ] 접근 통제: 스테이징 서버·배포 서버·서명 키 (N-01)

8.5 스냅샷

- [ ] 스냅샷 운영: 날짜별 스냅샷, 같은 스냅샷은 같은 결과, 현장 장치는 prod만 참조 (F-16, F-17)
- [ ] 추적: 장치 버전·스냅샷·SBOM 상호 추적 (N-04)

8.6 SBOM·취약점

- [ ] SBOM 생성: 이미지(설치 구성)별 CycloneDX 1.4/1.5 JSON 자동 생성 (F-19)
- [ ] 수동 항목: libPdu.a, KISA SHA-256 구현 포함 (F-20)
- [ ] KT 검증: 최상위 컴포넌트 일치, purl, 직접·전이 의존성, 파일 크기, 파일명 자동 점검 통과 (F-19)

- [ ] 취약점 대조: 스케줄 수행, 취약 패키지를 넣은 시험 스냅샷에서 탐지, 결과를 반입본과 함께 제공 (F-21)
- [ ] KT 대응: 요청 시 합의한 기간 내 SBOM 제출·패치 배포 (F-22)

8.7 업그레이드

- [ ] e3-updater: 인증된 신호 수신 시 로컬 apt 실행, 인증 없는·변조 신호 무시, 앱 코드 미수정 (F-23)
- [ ] 결과 보고: 기동 점검(데몬, 통신) 후 성공/실패·설치 버전·실행 커널 버전 보고 (F-24)
- [ ] GW 중계: DP 경유로 신호 전달·apt 수령 (F-25)
- [ ] smm 오판 방지: 업그레이드 후 강제 재부팅이 발생하지 않음을 로그로 확인 (N-02)

8.8 현장 전환

- [ ] 카드 교체: 일괄 교체 절차, 장치당 방문 1회 (F-26)
- [ ] 설정 이관: nelite.conf 이관 후 장치 ID·네트워크·Host 연동 유지 (F-27)
- [ ] DB 복원: nelite.db는 Host 재다운로드로 복원, alarm.db는 이관하지 않음 (F-28)

8.9 운영·품질

- [ ] 자원: RAM 512MB, microSD 용량·쓰기 수명 범위 내 동작, apt 캐시·로그 보관 정책 (N-03)
- [ ] 운영 절차서: 검사 결과 확인 → 반입 승인 → 신호 전송 → 결과 확인 (N-05)

9. 요구 간 관계 (KT 요구 → 요구사항)

KT·정책 요구	대응 요구
제품 단위 SBOM 제출, CycloneDX/SPDX JSON	F-19
purl·직접/전이 의존성 필수	F-19, F-20
취약점 조치 후 재제출	F-21, F-22
폐쇄망, 외부 검사 후 반입	C-01, C-02, F-13~F-15, F-18
표준 apt	C-03, F-07, F-23
지속 보안 패치	F-16~F-18, F-23~F-25
타 프로젝트 적용	F-08

10. 용어

용어	설명
SBOM	소프트웨어 자재명세서. 구성 컴포넌트(이름, 버전, 의존 관계) 목록
CycloneDX / SPDX	SBOM 표준 형식
purl	컴포넌트 식별 문자열. 예: pkg:deb/debian/openssl@3.0.15
직접/전이 의존성	프로젝트가 직접 쓰는 라이브러리 / 그 라이브러리가 쓰는 라이브러리
Debian / apt / deb	리눅스 배포판 / 패키지 관리 도구 / 패키지 파일 형식
저장소, 미러	패키지 모음 서버 / 그 복제본
스냅샷	특정 시점의 저장소 내용을 고정한 것
aptly	저장소 스냅샷·서명을 지원하는 apt 저장소 관리 도구
스테이징 서버	외부망에서 저장소 미러링·자체 deb 반영·서명·보안 검사·시험을 수행하고 반입본을 만드는 서버
폐쇄망	외부 인터넷이 차단된 KT 시스템 망
EOL	지원 종료. 보안 패치 미제공 상태
Host	E3 장치가 연동하는 상위 관제 시스템
smm	E3 앱의 프로세스 감시 프로그램. 데몬 정체 시 장치 강제 재부팅
nelite.conf / nelite.db / alarm.db	장치별 설정 / 설정·계측 DB 스냅샷 / 경보 이력
e3-updater (가칭)	업그레이드 신호를 받아 apt를 실행하는 신규 공통 구성요소